LABORATUVAR 6 · ARMA MANTAR BARİYER · KİMYA TESİSİ GİRİŞİ

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad Mehmet Onur Boyraz · 245541023 | Grup | Tarih 20.10.2026

Senaryo V: Saat **10:15**. Sabah raporunda, Arma Mobil'deki paylaşılan vardiya amiri hesabına **gece 03:00'te tanınmayan bir konumdan** girildiği görülüyor. Aynı saatlerde Arma Kart'ın yapılandırma arayüzünde (HTTP/80) erişim izi var. Loop hassasiyeti, fotosel bypass ve yükselme gecikmesi değişmiş olabilir; **SF-1 parametreleri henüz doğrulanmadı**. Bariyerler çalışıyor, tanker trafiği yoğun. Güvenlik vardiya amiri sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24 saat / 72 saat / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır; ezber değil.

Çıktı — Incident Workflow (zaman çizgisi)

03:00	10:15	10:30	12:15	+24 saat	+72 saat	+14 gün
yetkisiz giriş	tespit	ilk 15 dakika	ilk 2 saat	erken uyarı	bildirim	son rapor
Paylaşılan Arma Mobil hesabıyla giriş, tanınmayan konum Arma Kart HTTP/80 sayfasına erişim **fark edilmedi**	Sabah raporunda şüpheli oturum görüldü **Olay ilan edilir;** zaman damgalı olay defteri açılır	**1 · Hareketi durdur,** şeridi boşalt **2 · 4G'yi kes —** kapatmadan **3 · Kanıtı dondur:** reset yok	SF-1 parametreleri + CRC + test Kanıt imajları ve loglar Paylaşılan hesap kapalı **Manuel mod**	Arma'ya kanıtla bildir (CRA erken uyarısı onun) USOM / sektörel SOME KVKK ön değerlendirmesi	Kök neden, etki, önlem Rol tablosu Gerekirse KVKK bildirimi (≤ 72 s)	Son rapor Kayıtlar arşivde, hash'li LAB 4 mimarisi takvime bağlı

Görev — zaman çizgisini doldurun

1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Kimi ararım?

- **OT güvenlik sorumlusu** — olay yöneticisi olur
- **Tesis güvenlik müdürü** — kapı ve görevliler
- **İSG uzmanı** — SF-1 doğrulaması
- **Entegratör / Arma servisi** — yerinde destek, uzaktan değil

İlk üç eylem (sırası önemli)

1. **Emniyet:** otomatik ve uzaktan komutlar kesilir; bariyerler yukarıda kalır, yayalar şeritten çekilir, tankerler bekleme alanına alınır.
2. **Kontrol altına al:** 4G'nin anteni/SIM'i çıkarılır, kulübe PC'si ağdan ayrılır — **kapatılmadan**, çünkü bellekteki iz kaybolur.
3. **Kanıt:** "reset yok" kuralı ilan edilir; ekranlar fotoğraflanır, saatler not edilir, olay defteri başlar.

2 İlk 2 saat: Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

Emniyet güvende mi?	**Doğrulanana kadar "hayır" kabul edilir.** Önce kanıt alınır, sonra test edilir (sıra önemli: test, kartın durumunu değiştirebilir). (1) SF-1 parametreleri (loop hassasiyeti, fotosel durumu, yükselme gecikmesi, enerji dönüşü davranışı) okunur ve LAB 1'deki referans değerlerle, CRC'yle karşılaştırılır. (2) Fonksiyon testleri: test aracı loop'ta → yükselme yok; fotosel kesilince → durup iner; yaya maketi; acil stop. (3) Pano ve manuel indirme vanası mühürleri kontrol edilir. **Testler geçene kadar** bariyer yalnız manuel modda, görevlinin gözü önünde ve butona basılı tutarak yükseltilir.
Hangi kanıt korunur?	Arma bulutundan oturum ve komut logları (resmi yazıyla talep) · Arma Kart'ın olay günlüğü ve o anki parametre dökümü, **değiştirilmeden** · 4G router'ın bağlantı ve port yönlendirme kayıtları · kulübe PC'sinin adli imajı (WOC, TeamViewer, USB geçmişi) · 02:30–10:30 arası kamera kayıtları · plaka/kart geçiş kayıtları · vardiya defteri. Her parçanın hash'i alınır, delil zinciri formu doldurulur.
Hangi hesap kapatılır?	Paylaşılan Arma Mobil vardiya amiri hesabı **hemen**; amirlere geçici kişisel hesap + MFA verilir. Kanıt alındıktan sonra: Arma Kart'ın varsayılan yönetici parolası, 4G router yönetici parolası değişir; TeamViewer erişimi kapatılır; buluttaki açık oturumlar ve tokenlar iptal edilir.

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

> **Önce kimin bildirdiğini ayıralım:** CRA'nın 24 saatlik erken uyarısı **üreticinin** yani Arma'nın yükümlülüğü (aktif istismar edilen bir açık ya da ürünün güvenliğini etkileyen ağır bir olay varsa). Tesis olarak bizim işimiz, Arma'nın bu süreyi tutturabilmesi için onu saatler içinde kanıtla bilgilendirmek. Gerekirse ulusal CSIRT'e (USOM / sektörel SOME) de bildiririz; CRA Madde 15 bu gönüllü bildirimi de mümkün kılar. Hazır olması gerekenler:
>
> - **Ne oldu:** paylaşılan hesapla yetkisiz giriş (03:00), Arma Kart yapılandırma sayfasına erişim; zaman çizgisi.
> - **Ürün ve sürüm:** Arma Kart [EE51KAR] firmware sürümü, Arma Mobil ve bulut bileşeni.
> - **Kötü niyet şüphesi:** evet — tanınmayan konum ve gece saati. Erken uyarı bunu açıkça sorar.
> - **İlk etki:** SF-1 parametreleri değişti mi (test sonucu), kapı manuel modda, yaralanma yok.
> - **Alınan önlemler:** izolasyon, hesap kapatma, manuel mod; iletişim kişisi.
> - **Kişisel veri:** plaka ve giriş kayıtları görüntülendiyse KVKK ön değerlendirmesi başlar.

4 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

> **Kök neden (ön bulgu):** hiç değişmemiş paylaşılan Arma Mobil parolası + MFA yok + Arma Kart'ta varsayılan parola + 4G port yönlendirme. LAB 3'teki S1 ve R4 zincirlerinin gerçekleşmiş hali. **Etki:** hangi SF-1 parametresinin neye değiştiği; kaç saat manuel mod ve tanker gecikmesi; yaralanma yok; kişisel veri görüntülenip görüntülenmediği. **Önlem:** LAB 4 hedef mimarisinin ilk adımları öne çekilir (kişisel hesap + MFA, port yönlendirmenin kaldırılması, fotosel bypass'ın kaldırılması) ve LAB 5'teki geçici bağımsız emniyet rölesi takılır.

Rol	72 saat içinde ne yapıyor?
Olay yöneticisi (OT güvenlik)	Zaman çizelgesi ve karar kaydı; bildirim taslakları; düzeltme planı ve takvimi
Güvenlik müdürü	Manuel mod ve görevli prosedürü; kamera ve mühür kontrolleri; kapıda fiziksel müdahale izi
İSG uzmanı	SF-1 doğrulaması ve test raporu; şerit güvenliği; çalışanların bilgilendirilmesi
Entegratör + Arma	Log ve firmware analizi, kök neden. Arma: CRA 72 saatlik bildirimi ve düzeltme; etkilenen diğer kullanıcıları uyarma
IT	Hesap yönetimi; kulübe PC imajı; bulut loglarının resmi talebi
Hukuk / KVKK sorumlusu	Kişisel veri değerlendirmesi; gerekirse KVKK bildirimi (en geç 72 saat); resmi yazışmalar
Üst yönetim	Kaynak onayı; dış iletişim kararı

5 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

Kayıt	Kaynak	Neden önemli?	Nasıl korunur?
Oturum ve komut logları	Arma bulutu	03:00 girişinin kimden ve nereden geldiği	Resmi yazıyla talep; imzalı/hash'li dışa aktarım
Parametre dökümü + değişiklik geçmişi	Arma Kart	SF-1'in neyinin değiştiği	Olay anındaki döküm + CRC, değiştirilmeden
Bağlantı ve port yönlendirme kayıtları	4G router	Saldırının ağ yolu	Yapılandırma + log dışa aktarımı, hash
Adli imaj, olay günlükleri, WOC/TeamViewer/USB geçmişi	Kulübe PC	İkinci bir kapı kullanıldı mı?	İmaj + hash; orijinal disk mühürlü
Video kayıtları	NVR	Kapıda fiziksel müdahale var mı?	Olay günü + önceki 24 saat; kopya + hash
Plaka / kart geçiş kayıtları	Geçiş kontrol	Şüpheli araç geçişi var mı?	Dışa aktarım + hash
Vardiya defteri, karar kaydı, iletişim	Ekip	Kim neyi ne zaman bildi, neye karar verdi	İmzalı, zaman damgalı
SF-1 test raporları (öncesi / sonrası)	İSG	Emniyetin geri geldiğinin kanıtı	İmzalı; LAB 1 haritasına bağlı
Delil zinciri formları	Olay yöneticisi	Kanıtın hukuken geçerli kalması	Her teslimde imza + hash

En sık hata: "Resetleyip devam edelim." Bu makinede iki kez yanlış: (1) Arma Kart'ın hafızasındaki olay ve parametre izlerini sonsuza dek siler; (2) enerji dönüşünde bariyer beklenmedik şekilde hareket edebilir (SF-3 / GR-5). Önce emniyet, hemen sonra kanıt.

Kim neyi bildirir? Arma (üretici): CRA Madde 14 — aktif istismar edilen açıkta 24 s erken uyarı, 72 s bildirim, düzeltme yayımlandıktan sonra en geç 14 gün içinde son rapor; ağır olayda son rapor 1 ay. Bildirim ENISA'nın tek bildirim platformu üzerinden yapılır (11.09.2026'dan beri yürürlükte). Tesis (kullanıcı): üreticiyi bilgilendirir; ulusal CSIRT'e (USOM / SOME) bildirir; kişisel veri ihlalinde KVKK'ya en geç 72 saat içinde bildirir. Tesis AB'de olsaydı NIS2 Madde 23 de aynı 24 s / 72 s / 1 ay takvimini tesise yüklerdi. V senaryo ve kişiler eğitim kurgusudur, **Arma ürünü hakkında iddia değildir**.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.